

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
		Least Privilege
		Disaster recovery plans
		Password policies
		Separation of duties
		Firewall
		Intrusion detection system (IDS)
		Backups
		Antivirus software
		Manual monitoring, maintenance, and intervention for legacy systems
		Encryption
		Password management system
		Locks (offices, storefront, warehouse)
		Closed-circuit television (CCTV) surveillance
		Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
		Only authorized users have access to customers’ credit card information.
		Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
		Implement data encryption procedures to better secure credit card transaction touchpoints and data.
		Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
		E.U. customers’ data is kept private/secured.
		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
		Ensure data is properly classified and inventoried.
		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
		User access policies are established.
		Sensitive data (PII/SPII) is confidential/private.
		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
		Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Security Audit for Botium Toys

At present, the security posture is poor. There are a number of areas which need improvement, predominantly technical controls and administrative/managerial controls. I will first list the areas in which the company is succeeding:

- Firewall - Having a firewall present is an excellent preventative measure to defend the companies network from intruders by filtering unwanted and malicious traffic
- Antivirus software - This software scans the company computers and ensure the quarantining of known threats to the system

- Locks, CCTV and fire detection system - All preventative and detective methods of securing the companies physical assets. The company should ensure proper maintenance of these items to ensure they remain effective however at present, they are doing well
- The company has a plan to inform EU customers within 72 hours if data is compromised/ there is a breach. This ensures the company remains GDPR compliant, this is essential to not face penalties and fines from governmental agencies

The following is a list of recommendations, the reason for the recommendation, how it will affect the company if changes are not made:

<u>Security element</u>	<u>Recommendation</u>	<u>Risk associated</u>
Least Privilege	At present, all users have access to all information that is stored and retained by the company. This will need to be amended so that users only have access to the information of which they require for their role and nothing more.	This can be a HIGH risk if left unchecked. At present, if there were to be a malicious insider, or a threat actor who has gained access to a user's account, all information is at their disposal. This could cause a mass data breach for the company, leading to penalties, fines, loss in confidence and other ramifications
Disaster recovery plan	Plans will need to be developed in order to allow for business continuity	At present, if data is lost, the company has no plan in place to be able to recover or continue with business. These plans are a corrective measure and more so a contingency plan for the company. Whilst not an immediate risk, this should be a MEDIUM priority for the company
Separation of duties	This is a preventative measure widely accepted and recognised. In essence, no one person should hold enough privileges to abuse the system. Critical roles, such as signing paychecks and issuing them should be divided to separate users	This is a HIGH risk vulnerability at present. One user at present for example would be able to create pay checks, sign off and then issue these paychecks for any amount they wish. The same can be done for accessing a variety of personal and sensitive information about the company

Password policies	The company at present does implement the use of passwords, however it does not adopt the PCI DSS guidance of secure password management. Password's for account should be of a minimum 8 characters, containing a mix of lower case and uppercase letters, the use of a number and also a symbol	This is a MEDIUM risk vulnerability at present. If passwords are easy to guess, this allows a threat actor to easily access systems, which could allow them access to sensitive information
Intrusion detection system (IDS)	This is a detective type of control. Having an IDS will allow a system to detect anomalous traffic in a network. In essence, this system will detect when unauthorised users or an unusual source is trying to access the network	At present, this is a HIGH risk vulnerability. The company has now technical way of detecting any anomalous traffic. An IDS will automate detection and save staff hours of going through logs and monitoring traffic constantly to detect an anomaly
Backups	Should anything occur to the companies systems and data were to be wiped, there are currently no backups. This could essentially destroy the entire company. It is recommended that this is rectified immediately	This is a HIGH risk vulnerability. Should anything happen to the network or information stored on the network, the results could potentially wipe the entire company. A full loss of customer data and all inventory etc. with no way of retrieving any information
Manual monitoring, maintenance, and intervention for legacy systems	A system or schedule needs to be implemented whereby legacy systems are checked on a regular basis at regular intervals.	This is a LOW risk for the company. Staff are already maintaining checks of the systems however they do not have a schedule in place. With a structured approach this can be easily rectified
Encryption	This is a major deterrent. This ensures that when data is stored or is sent, it is saved in an encrypted file, ensuring that it cannot be so easily read without the appropriate access	This is a HIGH risk vulnerability. If a threat actor or malicious insider were to access the system, it would not be difficult for them to obtain information as they would not require a separate key to decode information

Password management system	A system which would enforce the password policies which I have previously spoken about	This is a MEDIUM risk vulnerability. I would encourage the company to first begin with implementing the password policy practice first. The management system allows an easier, autonomous method of ensuring that staff are complying with the practice and changing passwords at regular intervals/ allowing them an easier way to reset passwords when needed to
----------------------------	---	--

Payment Card Industry Data Security Standard - PCI DSS

Botium Toys currently fails to meet all four PCI DSS best practices assessed in this audit.

Best Practice	Status
Only authorised users have access to customers' credit card information	No
Credit card information is stored, accepted, processed, and transmitted in a secure environment	No
Data encryption procedures are implemented to secure credit card transaction touchpoints and data	No
Secure password management policies are adopted	No

At present, all employees have unrestricted access to internally stored data, which includes cardholder information. This directly violates the PCI DSS principle of restricting access to only those whose role requires it. Additionally, credit card data is not encrypted in transit or at rest, meaning any unauthorised access to the internal database would expose cardholder data in readable form. Password policies exist but do not meet the minimum complexity requirements stipulated by PCI DSS guidance.

Non-compliance with PCI DSS carries serious consequences. Depending on the volume of transactions processed, Botium Toys could face fines ranging from \$5,000 to \$100,000 per month from card brands such as Visa and Mastercard, potential suspension of the ability to process card payments, and mandatory costly forensic audits in the event of a breach. Given that the company processes card payments both in-store and online, achieving PCI DSS

compliance should be treated as a high priority. The recommendations covering least privilege, encryption, and password policy implementation will directly address these gaps.

General Data Protection Regulation (GDPR)

Best Practice	Status
EU customers' data is kept private and secured	No
A plan is in place to notify EU customers within 72 hours if their data is compromised	Yes
Data is properly classified and inventoried	No
Privacy policies, procedures, and processes are enforced to properly document and maintain data	Yes

The company has correctly established a 72-hour breach notification plan for EU customers and has documented privacy policies in place — both of which are positive indicators of GDPR awareness. However, EU customer data is not currently kept secure or private in practice. The absence of encryption means that personal data stored internally is accessible in plaintext, and the lack of least privilege access control means that data is not adequately restricted to those with a legitimate need. Furthermore, assets and data have not been formally classified or inventoried, meaning the company cannot fully account for what personal data it holds or where it resides — a core GDPR accountability requirement.

GDPR non-compliance carries some of the most significant financial penalties in data protection law. Serious infringements can result in fines of up to €20 million or 4% of annual global turnover, whichever is higher. Beyond financial penalties, a breach involving EU customer data without adequate protective measures in place could result in reputational damage and loss of customer trust. Implementing encryption and least privilege access, alongside conducting a formal data classification exercise, will bring the company significantly closer to full GDPR compliance.

System and organisation controls (SOC type 1 and SOC type 2)

Botium Toys meets some SOC criteria but has critical gaps, particularly around access control and data confidentiality.

Best Practice	Status
User access policies are established	No
Sensitive data (PII/SPII) is confidential and private	No
Data integrity ensures data is consistent, complete, accurate, and validated	Yes
Data is available to individuals authorised to access it	Yes

The IT department has maintained data integrity and ensured that systems remain available, which are positive foundations. However, the company has not established formal user access policies, meaning there is no documented framework governing who can access what data and under what circumstances. As a result, sensitive personally identifiable information (PII) and special category PII (SPII) are not adequately protected — all employees can currently access this data regardless of their role.

SOC Type 1 focuses on the design of internal controls over financial reporting, while SOC Type 2 evaluates whether those controls operate effectively over a defined period. Failure to meet these standards can undermine stakeholder and investor confidence, particularly for organisations seeking to demonstrate trustworthiness to business partners or clients. The gaps identified — specifically the absence of user access policies and the lack of data confidentiality controls — should be addressed through the implementation of least privilege, separation of duties, and encryption as detailed in the recommendations above.